INTERAFAS

Plan de Respuesta ante Incidentes de Seguridad de la Información

Entregable 5 — PR02-31 a PR02-40
Octubre 2026

Alumno	Luis Emmanuel Aronia Silva
Actividad	05. Plan de Respuesta ante Incidentes (PR02-31 a PR02-40)
Materia	CNOIV Programación WAP
Maestro	Servando López Contreras

Este plan se construye sobre los hallazgos del Informe de Seguridad Ofensiva (INTERAFAS-LAB), la Propuesta de Gobernanza ISO/IEC 27001 y el Plan de Comunicación de Crisis. Opera como el marco operativo que activa la respuesta técnica y de negocio cuando se materializan los riesgos identificados (R-02, R-06, R-16, R-21, R-22, R-23).

PR02-31 | Propósito, alcance y clasificación

Propósito. Establecer el proceso formal, repetible y auditable para detectar, analizar, contener, erradicar, recuperar y aprender de los incidentes de seguridad de la información que afecten a INTERAFAS, con énfasis en la protección de datos personales y financieros de los ciudadanos, la integridad de los procesos de facturación y contratación, y la continuidad de la infraestructura crítica de agua y energía.

Alcance. Cubre todos los sistemas dentro del SGSI: portal web institucional y APIs, sistema de facturación y pagos, padrón de proveedores, procesos de atención ciudadana, gestión de sesiones y credenciales, y la interfaz de supervisión de la red operacional (OT/telemetría). Incluye incidentes que involucren personal interno, proveedores o actores externos.

Concepto de incidente. Cualquier evento, confirmado o altamente probable, que comprometa la confidencialidad, integridad o disponibilidad de la información o de los sistemas de INTERAFAS, o que represente un riesgo material para la continuidad del servicio público o la confianza ciudadana.

Criterios de severidad y condiciones de activación.

Nivel	Criterio	Ejemplos del laboratorio	Activación
Crítico	Impacto en infraestructura OT, interrupción del suministro, o fuga masiva de PII con evidencia de exfiltración.	VULN-18/19/20 (Catastrophic State), VULN-03+07 (dump masivo)	Inmediata (Comité de Crisis + Centro de Operaciones)
Alto	Fuga de datos de un subconjunto de usuarios, fraude en pagos, o compromiso de credenciales administrativas.	VULN-03, VULN-12/13, VULN-10	Dentro de 1 hora
Medio	Exposición de código o configuraciones residuales sin evidencia de explotación activa.	VULN-01, VULN-02, VULN-04	Dentro de 4 horas
Bajo	Hallazgos de configuración o vulnerabilidades sin evidencia de explotación.	VULN-05, VULN-11	Dentro de 24 horas

La activación del Plan de Comunicación de Crisis (Entregable 4) ocurre automáticamente cuando el incidente se clasifica como Alto o Crítico con impacto en la confianza pública.

PR02-32 | Roles y responsabilidades

Se establece un Equipo de Respuesta a Incidentes (ERI) bajo la coordinación del Área de Ciberseguridad y Gobierno de TI, con apoyo de las direcciones funcionales.

Rol	Responsable	Funciones clave
Líder del ERI	Responsable de Ciberseguridad y Gobierno de TI	Coordina la respuesta técnica, clasifica el incidente, decide contención y escalamiento, y presenta el informe final.
Responsable Técnico (IT)	Área de Infraestructura y Redes + Desarrollo	Ejecuta contención, erradicación y recuperación en sistemas web/API. Preserva evidencia.
Responsable Técnico (OT)	Jefatura de Monitoreo de Planta / Centro de Operaciones	Evalúa impacto en telemetría y actuadores. Aísla segmentos OT. Valida restauración de parámetros operativos.
Dirección General	Director General	Aprueba decisiones de alto impacto (suspensión de servicios, notificación a autoridades, mensaje público).
Asesor Jurídico	Dirección Jurídica y Cumplimiento	Evalúa obligaciones de notificación (LFPDPPP, autoridades reguladoras). Revisa comunicaciones.
Comunicación	Jefatura de Comunicación Social y Vocería	Ejecuta el Plan de Comunicación de Crisis. Gestiona medios y redes.
Atención al Ciudadano	Dirección de Atención Ciudadana	Gestiona el volumen de consultas. Notifica a usuarios afectados.

Terceros (proveedores de hosting, pasarela de pagos, contratistas de OT) participan mediante funciones claramente definidas en sus contratos, con obligación de notificar incidentes en un máximo de 4 horas.

PR02-33 | Preparación, detección y reporte

Preparación.

- Inventario actualizado de activos de información y sistemas (alineado a la Sección 04 del entregable ISO).
- Canales de reporte definidos: correo iri@interafas.gob.mx, teléfono interno 24/7 del Centro de Operaciones, y formulario interno en el portal de empleados.
- Herramientas de detección: logs centralizados del portal y APIs, alertas de telemetría OT, monitoreo de cambios en archivos críticos (.env, firmware), y revisión periódica de Directory Listing y archivos residuales.
- Capacitación anual del personal en identificación y reporte de incidentes.
- Acuerdos de nivel de servicio con proveedores para preservación de logs y respuesta.

Fuentes de detección. Monitoreo de logs de aplicación y servidor web, alertas del Centro de Operaciones (desviaciones de presión, caudal o disponibilidad), reportes de usuarios (recibos alterados, accesos no autorizados), inteligencia de amenazas, y hallazgos de auditorías o pruebas de penetración.

Registro y reporte. Todo incidente se registra en el sistema de tickets interno con número único, hora de detección, fuente, activos afectados y clasificación preliminar. El reporte inicial se envía al Líder del ERI dentro de los 15 minutos de la detección.

PR02-34 | Análisis y priorización

Una vez reportado, el Líder del ERI realiza el triage inicial en un máximo de 30 minutos para incidentes Alto/Crítico.

Procedimiento de triage:

- Validación: confirmar que el evento es real y no un falso positivo.
- Alcance: identificar sistemas, datos y usuarios afectados (usar correlaciones de logs y telemetría).
- Clasificación: aplicar los criterios de severidad de PR02-31.
- Priorización: Crítico > Alto > Medio > Bajo. Los incidentes OT siempre tienen prioridad sobre IT cuando hay riesgo de continuidad del suministro.
- Preservación de evidencia: capturar logs, dumps de memoria (si aplica), capturas de red y estado de configuraciones antes de cualquier contención agresiva.
- Escalamiento: notificar al Comité de Crisis si la severidad es Alto o Crítico con impacto público.

PR02-35 | Contención

La contención busca limitar el daño inmediato sin destruir evidencia ni comprometer innecesariamente la continuidad del servicio.

Estrategias de contención inmediata:

- Bloqueo de cuentas o sesiones comprometidas (revocación de PHPSESSID, bloqueo de IPs).
- Deshabilitación temporal de endpoints afectados (ej. validar-referencia.php, pago.php).
- Aislamiento de segmentos de red (especialmente OT si se detecta movimiento lateral).
- Revocación de tokens o certificados expuestos.
- Activación de modo de solo lectura en sistemas de facturación si hay evidencia de fraude activo.

Contención prolongada: Mantener sistemas en modo degradado controlado mientras se prepara la erradicación. Coordinar con el Centro de Operaciones para asegurar que la contención OT no genere riesgos de seguridad física (ej. no deshabilitar telemetría de presión sin alternativas).

Toda acción de contención se documenta con hora, responsable y justificación.

PR02-36 | Erradicación y remediación

Una vez contenido, se elimina la causa raíz y la persistencia del atacante.

Acciones típicas (alineadas a los hallazgos del laboratorio):

- Eliminación de archivos residuales (.zip, .bak, .env) y deshabilitación de Directory Listing (VULN-01, VULN-04).
- Corrección de autorización a nivel de objeto en APIs (BOLA) y reemplazo de IDs secuenciales (VULN-03, VULN-12).
- Parcheo de inyecciones SQL y validación de entrada (VULN-07).
- Sanitización de salidas y revisión de reportes almacenados (VULN-08).
- Rotación obligatoria de identificadores de sesión y revisión de lógica de autenticación (VULN-10).
- Implementación de validación de límites y firmas criptográficas en actualizaciones de firmware OT (VULN-18, VULN-20).
- Eliminación de cuentas de backdoor, tareas programadas o persistencia en sistemas comprometidos.

Antes de recuperar, se valida que los controles corregidos funcionan mediante pruebas controladas y que no existen mecanismos de persistencia residuales.

PR02-37 | Recuperación

La recuperación restablece las operaciones normales de forma segura y controlada.

Pasos:

- Restauración desde respaldos limpios (verificados) o reconstrucción de sistemas afectados.
- Pruebas funcionales y de seguridad (incluyendo verificación de que las vulnerabilidades corregidas no reaparecen).
- Monitoreo reforzado durante al menos 72 horas post-recuperación (logs, telemetría, anomalías de comportamiento).
- Criterios de retorno a operación normal: ausencia de indicadores de compromiso, validación de controles por el Líder del ERI, y autorización de la Dirección General en casos Críticos.
- Mecanismos de rollback: si la recuperación introduce inestabilidad, se revierte al estado contenido anterior y se reevalúa.

PR02-38 | Coordinación y comunicación

El escalamiento y la comunicación se coordinan con el Plan de Comunicación de Crisis (Entregable 4).

Escalamiento interno: Líder del ERI → Dirección de TI y Operaciones → Dirección General → Comité de Crisis (si aplica).

Coordinación externa:

- Autoridades reguladoras y de protección de datos (notificación conforme a plazos legales).
- Proveedores y terceros (pasarela de pagos, contratistas OT) mediante canales preestablecidos.
- Medios y ciudadanía: a través del vocero oficial, siguiendo las plantillas del Plan de Comunicación de Crisis.
- En incidentes OT con impacto en el suministro, se activa la coordinación con autoridades de protección civil y el Centro de Operaciones Metropolitano.

Todas las comunicaciones externas son revisadas por el Asesor Jurídico antes de su emisión.

PR02-39 | Playbooks operativos

Se definen playbooks derivados directamente de los escenarios observados en INTERAFAS-LAB. Cada uno incluye disparador, responsables, acciones, evidencia, contención, recuperación y criterio de cierre.

Playbook 1: Exposición de archivos residuales y Directory Listing (VULN-01 / VULN-04)

Disparador	Detección de Directory Listing público o descarga de archivos .zip/.bak/.env desde rutas no autenticadas.
Responsables	Responsable Técnico (IT) + Líder del ERI
Acciones	1. Confirmar exposición. 2. Deshabilitar Directory Listing. 3. Eliminar archivos residuales. 4. Revisar logs de acceso para identificar descargas previas. 5. Rotar cualquier secreto expuesto.
Evidencia	Capturas de robots.txt, listado de directorio, contenido de .env, logs de acceso.
Contención	Bloqueo de la ruta afectada y eliminación inmediata de artefactos.
Recuperación	Implementar proceso post-despliegue que elimine residuales. Verificar que no queden secretos activos.
Cierre	Confirmación de que la ruta ya no es accesible y que no hay evidencia de uso malicioso de los secretos.

Playbook 2: Fuga masiva de PII y datos de facturación por IDOR (VULN-03 / VULN-12)

Disparador	Acceso a expedientes o historiales de terceros mediante manipulación de parámetros (account, id).
Responsables	Líder del ERI + Dirección Jurídica + Atención al Ciudadano
Acciones	1. Identificar alcance de la fuga. 2. Revocar sesiones sospechosas. 3. Implementar autorización a nivel de objeto. 4. Notificar a usuarios afectados.
Evidencia	Logs de API, capturas de respuestas con datos de terceros, registros de cuentas consultadas.
Contención	Deshabilitación temporal de endpoints de consulta o restricción por IP/sesión.
Recuperación	Despliegue de corrección BOLA. Revisión de integridad de datos. Monitoreo de consultas anómalas.
Cierre	Confirmación de que no es posible acceder a datos ajenos y que los afectados fueron notificados.

Playbook 3: Inyección SQL en validación de referencias (VULN-07)

Disparador	Comportamiento anómalo en validar-referencia.php o extracción de datos mediante payloads booleanos.
Responsables	Responsable Técnico (IT) + Líder del ERI
Acciones	1. Confirmar inyección. 2. Deshabilitar el endpoint. 3. Revisar logs de consultas SQL. 4. Aplicar consultas parametrizadas.
Evidencia	Payloads utilizados, respuestas del servidor, logs de base de datos.
Contención	Bloqueo inmediato del endpoint y revisión de privilegios de la cuenta de base de datos.
Recuperación	Parche con prepared statements. Pruebas de regresión. Rotación de credenciales de BD si hubo exposición.

Cierre	Confirmación de que el endpoint ya no es inyectable y no hay evidencia de extracción adicional.

Playbook 4: XSS almacenado en sistema de reportes (VULN-08)

Disparador	Ejecución de script almacenado en reportes o visualización de contenido no sanitizado.
Responsables	Responsable Técnico (IT) + Líder del ERI
Acciones	1. Identificar reportes comprometidos. 2. Sanitizar o eliminar contenido malicioso. 3. Implementar codificación de salida.
Evidencia	Capturas del payload ejecutado, logs de reportes, sesiones afectadas.
Contención	Deshabilitación temporal de la visualización de reportes o filtrado de contenido.
Recuperación	Despliegue de sanitización. Revisión de otros campos de entrada de usuario.
Cierre	Confirmación de que no es posible almacenar ni ejecutar scripts en reportes.

Playbook 5: Compromiso de la red operacional OT — Firmware y alteración de parámetros (VULN-18 / VULN-19 / VULN-20)

Disparador	Detección de firmware no firmado, mapeo anómalo de topología, o desviación de setpoints de presión que genera estado catastrófico en telemetría.
Responsables	Responsable Técnico (OT) + Centro de Operaciones + Líder del ERI + Dirección General
Acciones	1. Aislar el segmento OT afectado. 2. Restaurar parámetros a valores baseline (4.2 bar). 3. Validar integridad del firmware. 4. Revisar accesos de mantenimiento.
Evidencia	Logs de telemetría, archivos de firmware cargados, registros de sesión de mantenimiento, capturas del HMI en estado catastrófico.
Contención	Aislamiento de red OT, deshabilitación de carga de firmware remoto, retorno a operación manual si es necesario.
Recuperación	Restauración de firmware firmado y parámetros validados. Pruebas de presión controladas. Monitoreo reforzado de telemetría.
Cierre	Confirmación de que los setpoints están dentro de rangos seguros, el firmware es legítimo, y no hay persistencia en el sistema OT.

Estos cinco playbooks cubren los escenarios más representativos del laboratorio. Se mantendrán actualizados conforme se identifiquen nuevos vectores.

PR02-40 | Post-incidente y mejora

Una vez cerrado el incidente, se realiza una revisión formal para extraer lecciones y mejorar el proceso.

Actividades de cierre:

- Informe final del incidente: cronología, alcance, acciones tomadas, impacto real y lecciones aprendidas.
- Reunión de lecciones aprendidas con el ERI y áreas involucradas (dentro de los 10 días hábiles posteriores al cierre).
- Identificación de acciones correctivas y preventivas (actualización de controles, capacitación, mejoras en detección).
- Actualización de playbooks, políticas y la matriz de riesgos si el incidente revela nuevos escenarios.
- Métricas de desempeño: tiempo de detección, tiempo de contención, tiempo de recuperación, número de usuarios afectados, y efectividad de la comunicación.

Seguimiento. Las acciones correctivas se registran con responsable y fecha compromiso. El Líder del ERI da seguimiento hasta su cierre y reporta el avance a la Dirección de TI y Operaciones y, cuando corresponda, a la Alta Dirección.

Este proceso de mejora continua alimenta la revisión periódica del SGSI y del presente Plan de Respuesta ante Incidentes.